
CLUSTER

Backend API Audit Report

Spring Boot 3.x — Post-Redesign Review

Commit: 30b371f (master) — 162 files changed, +3,979 / -6,068 lines

Confidential — Internal Use Only | May 2026

Executive Summary

The backend engineer completed a major redesign of the Clusteer Spring Boot API. The entire internal banking layer (VFD MicroFinance Bank), direct blockchain interaction layer (Django Blockchain Engine), and internal wallet system have been removed. In their place, **Quidax** now serves as the custodial ramp partner for all on-ramp (NGN to Crypto) and off-ramp (Crypto to NGN) flows.

The audit found 4 critical bugs that must be fixed before deployment, including an inverted webhook filter that prevents any transaction from completing, and a Firebase private key committed to the repository.

1. Architecture Changes

Before vs After

Component	Before	After
Banking	VFD MicroFinance Bank (662 lines)	REMOVED — Quidax handles fiat
Blockchain	Django Engine HTTP client (636 lines)	REMOVED — Quidax handles crypto
Wallets	Internal custodial (WalletService, 950 lines)	REMOVED — no internal wallets
Ramp Partner	None (direct bank + chain)	Quidax (376 lines, custodial ramp)
HTTP Client	Custom RestTemplate	Spring RestClient (5s connect, 30s read)
Order Flow	Direct bank transfer + chain tx	OTP-gated → Quidax API → webhook confirmation
Infra	Railway Docker only	+ docker-compose (Redis, health checks, resource limits)
Docs	None	OpenAPI / Swagger added
Exceptions	Generic	9 typed exception classes + GlobalExceptionHandler

New Flow Architecture

```
User → Frontend → Spring Boot API → Quidax (custodial ramp)
      ■ Quidax webhook → Spring Boot → update order/tx → notify user
```

Buy (NGN → Crypto): Create order → OTP verify → Quidax provides bank account → User pays NGN → Quidax sends crypto → Webhook confirms

Sell (Crypto → NGN): Create order + bank details → OTP verify → Quidax provides crypto address → User sends tokens → Quidax disburses NGN → Webhook confirms

2. Critical Issues (Fix Before Deploy)

These 4 issues will cause the system to malfunction or expose sensitive data.

2.1. Webhook Event Filter is INVERTED

File: QuidaxServiceImpl.java:267

The if-condition rejects events that ARE in the whitelist and accepts events that are NOT. As written, every valid webhook event from Quidax is rejected — no transaction will ever complete via webhook. Orders will stay in PENDING forever.

Fix: Negate the condition: `if (!List.of(...).contains(event))`

2.2. Webhook Endpoint Blocked by JWT Auth

File: AppConfig.java:56-62

The `/v1/webhook/**` path requires JWT authentication. Quidax webhook callbacks use HMAC signature verification, not JWT tokens. The endpoint is unreachable by Quidax.

Fix: Add `/v1/webhook/**` to the `permitAll()` list in the security filter chain.

2.3. Firebase Service Account Key in Repository

File: firebase-service-account.json (repo root)

A full Google Cloud service account private key is committed in plaintext. The key grants access to Firebase Auth, Firestore, and Storage for the entire project.

Fix: Rotate the key immediately in Google Cloud Console. Add `firebase-service-account.json` to `.gitignore`. Use `BFG Repo-Cleaner` to purge from git history.

2.4. Plaintext Password History Storage

File: UserServiceImpl.java:179, 1133-1138, 1191-1196

Passwords are stored as reversible Jasypt-encrypted text in `AccountSecurity.passwordHistory`, not as one-way hashes. If the Jasypt encryption key leaks, every historical password for every user is exposed.

Fix: Store `BCrypt` hashes in password history instead of raw/encrypted passwords.

3. High Priority Issues

#	Issue	File	Impact
5	getExchangeRate() is a stub — returns empty	PreferenceServiceImpl:218-225	Frontend shows no rates
6	generateDashboardData() is a stub	PreferenceServiceImpl:83-88	Admin dashboard empty
7	No @Positive on order amounts — zero/negative accepted	CreateP2PPurchaseOrder.java	Users can create invalid orders
8	No NUBAN validation on bank account numbers	CreateP2PSaleOrder.java	Invalid bank accounts accepted
9	CORS allows all origins (*)	AppConfig:90-98	Any website can call the API
10	30-day JWT token lifetime	JwtService:68	Excessive for financial app (24h recommended)

4. Medium Priority Issues

#	Issue	File
11	ddl-auto=update with no production profile — Hibernate auto-modifies prod schema	application.properties:31
12	No @Transactional on validateOrderOtp — partial failures corrupt state	P2POrderServiceImpl:330
13	No idempotency on webhook processing — duplicate processing possible	QuidaxServiceImpl:267+
14	Random instead of SecureRandom for password generation	Methods.java:147,384
15	No ownership check on notification read/delete	NotificationController:28-34
16	No ownership check on order view — any user can see any order	OrderController:52
17	GlobalExceptionHandler leaks dev messages to client	GlobalExceptionHandler:106
18	18 dead blockchain model files — unused code	models/blockchain/*
19	SecurityRepository lookup on every request (no caching)	JwtService:80-83
20	dateFilteredOrders JPQL type mismatch (Timestamp vs Long)	OrderRepository.java

5. API Endpoint Inventory

5.1 User Endpoints (/v1/user)

Method	Path	Auth	Purpose
POST	/register	None	Register new user
POST	/login	None	User login
POST	/send-email-otp	None	Send email OTP for 2FA
POST	/username/2fa/validate	None	Validate 2FA OTP
GET	/profile	CUSTOMER	Get own profile
PUT	/profile/update	CUSTOMER	Update profile
PUT	/identity/update	CUSTOMER	Upload KYC identity
PUT	/address/update	CUSTOMER	Upload KYC address
PUT	/avatar/update	CUSTOMER	Upload avatar
DELETE	/delete	CUSTOMER	Soft-delete account
POST	/send-verification	None	Send email verification
PUT	/verify	None	Verify email via token
POST	/account/recover	None	Request password recovery
PUT	/password/reset	None	Reset password with token
PUT	/password/update	CUSTOMER	Change password
PUT	/2fa/mail/update	CUSTOMER	Toggle email 2FA
GET	/2fa/request	CUSTOMER	Get 2FA QR code
PUT	/2fa/update	CUSTOMER	Toggle TOTP 2FA
PUT	/logout	CUSTOMER	Logout

5.2 Order Endpoints (/v1/order)

Method	Path	Auth	Purpose
POST	/purchase/create	CUSTOMER	Create buy order (NGN → Crypto)
POST	/sale/create	CUSTOMER	Create sell order (Crypto → NGN)
POST	/otp/resend	CUSTOMER	Resend order OTP
POST	/otp/validate	CUSTOMER	Validate OTP and execute order
GET	/id	ALL	Get order by ID
GET	/	CUSTOMER	Get own orders
GET	/user/orders	ADMIN	Get orders for specific user
GET	/all	ADMIN	List all orders
GET	/filter/date	ADMIN	Filter orders by date
GET	/filter/status	ADMIN	Filter orders by status

5.3 Transaction Endpoints (/v1/transaction)

Method	Path	Auth	Purpose
GET	/user	CUSTOMER	Get own transactions
GET	/user/{id}	ADMIN	Get transactions for user
GET	/ref	ADMIN	Get transaction by reference
GET	/all	ADMIN	List all transactions
GET	/filter	ADMIN	Multi-parameter filter

5.4 System Endpoints (/v1/system)

Method	Path	Auth	Purpose
GET	/dashboard	ADMIN	Dashboard data (STUB)
PUT	/preferences/update	SUPER	Update system preferences
GET	/preferences	None	Get system preferences
GET	/misc/banks	None	Get bank list (from Quidax)
GET	/misc/currency	None	Get supported currencies
GET	/misc/{id}/channel	None	Get channels for currency
GET	/exchange-rate	None	Get exchange rate (STUB)

5.5 Webhook + Notification + Admin

Method	Path	Auth	Purpose
POST	/v1/webhook/quidax/ramp	HMAC	Quidax webhook receiver
GET	/v1/notifications	CUSTOMER	Get notifications
PUT	/v1/notifications/{id}/read	CUSTOMER	Mark as read
DELETE	/v1/notifications/{id}/delete	CUSTOMER	Delete notification
DELETE	/v1/notifications/clear	CUSTOMER	Clear all
POST	/v1/admin/create	SUPER	Create admin
POST	/v1/admin/login	None	Admin login

6. Data Model Changes

Entities Added

Entity	Purpose
TransactionLog	Audit trail — full request/response for all Quidax API calls and webhooks
Channel	Blockchain networks per currency (BEP20, ERC20, TRC20)
Currency	Supported currencies (USDT, USDC, CNGN)

Entities Removed

Entity	Reason
Wallet, WalletAsset	No internal wallets in Quidax model
BlockchainAsset, BlockchainWallet	No direct blockchain management
Revenue	Revenue tracking removed
Parameter, PaymentMethod, Blockchain	Replaced by Currency + Channel
Chat (P2P)	P2P chat feature removed

New Enums

OrderStatus, OtpPrincipalType, TransactionLogDirection, TransactionLogStage, TransactionStatus, TransactionType — proper enum typing replaces string-based status tracking.

7. Recommended Fix Sequence

Priority	Action	Effort
P0 (today)	Fix inverted webhook filter (negate condition)	5 min
P0 (today)	Add /v1/webhook/** to permitAll()	5 min
P0 (today)	Rotate Firebase key, add to .gitignore, purge from history	30 min
P0 (today)	Hash password history with BCrypt instead of Jasypt	2 hours
P1 (this week)	Implement getExchangeRate() (Quidax or CoinGecko)	2 hours
P1 (this week)	Add @Positive validation on amounts	15 min
P1 (this week)	Restrict CORS to frontend domains	15 min
P1 (this week)	Reduce JWT lifetime to 24h + add refresh token	2 hours
P2 (next week)	Add @Transactional + idempotency to webhook handler	4 hours
P2 (next week)	Add ownership checks on notifications + orders	1 hour
P2 (next week)	Set up Spring profiles (dev/staging/prod)	1 hour
P2 (next week)	Remove dead blockchain model code	30 min
P3 (before launch)	Add Flyway migrations, remove ddl-auto=update	4 hours
P3 (before launch)	Implement admin dashboard data	8 hours
P3 (before launch)	Add rate limiting on auth endpoints	2 hours

Repository: github.com/OutbuildHQ/Clusteer-API | Branch: master

Audit performed: May 2026 | Auditor: Claude Opus 4.6